Architecture and Design

Identity Drift Detection in Autonomous AI Agents (AIDDS)

1. What the system does

AIDDS sits between AI agents and the tools, APIs and data they use. It records every action, compares it with the agent's declared role and the learned behaviour of that role, scores the risk, explains the score, and restricts the agent in steps. It never relies on token validity alone: a valid credential with out-of-role behaviour is still an alert.

2. Data flow

```
Agent  -->  Gateway / Proxy  -->  Tool / API / Data
                  |
                  |  event: agent, role, tool, resource, sensitivity,
                  |         destination, taint, delegation chain, time
                  v
              Event store
                  |
                  v
               Detector
                 1. Manifest rules, taint / kill-chain check  (inline, fast)
                 2. Markov rarity, JS divergence, CUSUM       (async)
                 3. Semantic drift vs role description        (async)
                  |
                  v
              Risk engine  -->  score 0-100 + explanation
                  |
                  v
          Response controller  -->  log / approve / restrict / isolate
                  |
                  v
          Dashboard + alert API
```

3. Components

Component	Responsibility	Key design choice
Gateway	Intercepts every tool call; enforces decisions	Rules run inline (milliseconds); ML runs async
Role manifest	Declares allowed tools, data classes, destinations per role	Signed, versioned YAML; changes need owner approval
Taint tracker	Marks untrusted content and follows it through the session	Taint travels with context and across agent hops
Baseline store	Per-ROLE profile: tool mix, sequences, volume, egress	Per-role so new agents are covered on day one
Detector	Produces signals from rules, statistics and semantics	Independent signals, so mimicry of one still fails others
Risk engine	Combines signals into a score and top reasons	Hard overrides for honeypot and kill chain
Response controller	Applies graduated action per agent or session	Only the affected agent is limited; others keep working
Dashboard	Live score, timeline, explanation, response log	Analyst feedback (false alarm / confirmed) stored

4. Role manifest (example)

```
role: procurement-agent
version: 3                      # signed by owner, change-controlled
allowed_tools: [supplier_price_api, create_purchase_request, read_catalog]
data_classes: [supplier, pricing, purchase_request]
forbidden_data_classes: [hr, payroll, finance_ledger]
egress_allowlist: [api.approved-supplier.com, erp.internal]
max_records_per_call: 200
requires_approval: [create_purchase_request > 100000]
```

5. Risk score (0-100)

Signal	Weight	Fires when
Role violation	35	Tool, data class or destination is outside the manifest
Taint-flow	25	Untrusted read, then sensitive access, then external egress
Resource sensitivity	15	Target holds PII, payroll, finance or privileged endpoints
Sequence rarity	10	Action sequence is unlikely under the role's Markov model
Semantic drift	10	Recent actions drift from the role description embedding
Velocity	5	Out-of-scope calls are spiking in the window

Score = sum of (weight x signal strength 0-1). **Overrides:** honeypot touched = 95; manifest breach after taint with external egress = at least 90. Every alert lists its top three contributing signals in plain language.

6. Graduated response

Score	Tier	Action
0-39	Observe	Log with full context; no interruption
40-69	Step-up	Pause only the risky action; ask a human to approve (Slack/Teams)
70-89	Restrict	Read-only, sensitive scopes revoked, short-lived token; agent keeps its safe tasks
90-100	Isolate	Quarantine the session, snapshot state for forensics; other agents unaffected

7. How each core challenge is handled

Challenge	Mechanism
Valid credentials hide the attack	Behaviour is judged against the manifest and role baseline, not the token
Indirect prompt injection	Provenance taint on every input; kill-chain rule on later privileged action
Legitimate change vs drift	Signed manifest updates for planned change; EWMA baselines absorb slow benign shifts
Little or no history	Role-level baseline plus manifest rules; rule weight high at first, statistical weight grows with data
Chains of agents	Delegation chain in every event; callee authority capped at intersection of caller scopes; partial score propagation
Evasion / slow drift	Independent signals, CUSUM on long windows, honeypot resources no legitimate agent touches

8. Technology

- **Prototype:** Python 3.12, FastAPI gateway, SQLite/Postgres, scikit-learn, sentence-transformers, React dashboard.
- **Production path:** Kafka/Redpanda event bus, ClickHouse/Postgres, OpenTelemetry, Kubernetes, vault for secrets.